



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

云平台的监管与审计

如何防范云计算服务商的上帝之手

栗蔚

中国信息通信研究院 主任工程师
云计算开源产业联盟 秘书长
数据中心联盟可信云服务工作组组长



中国互联网安全大会



360互联网安全中心

云服务商的上帝之手 ——客户的担忧

云客户的担忧



中国互联网安全大会

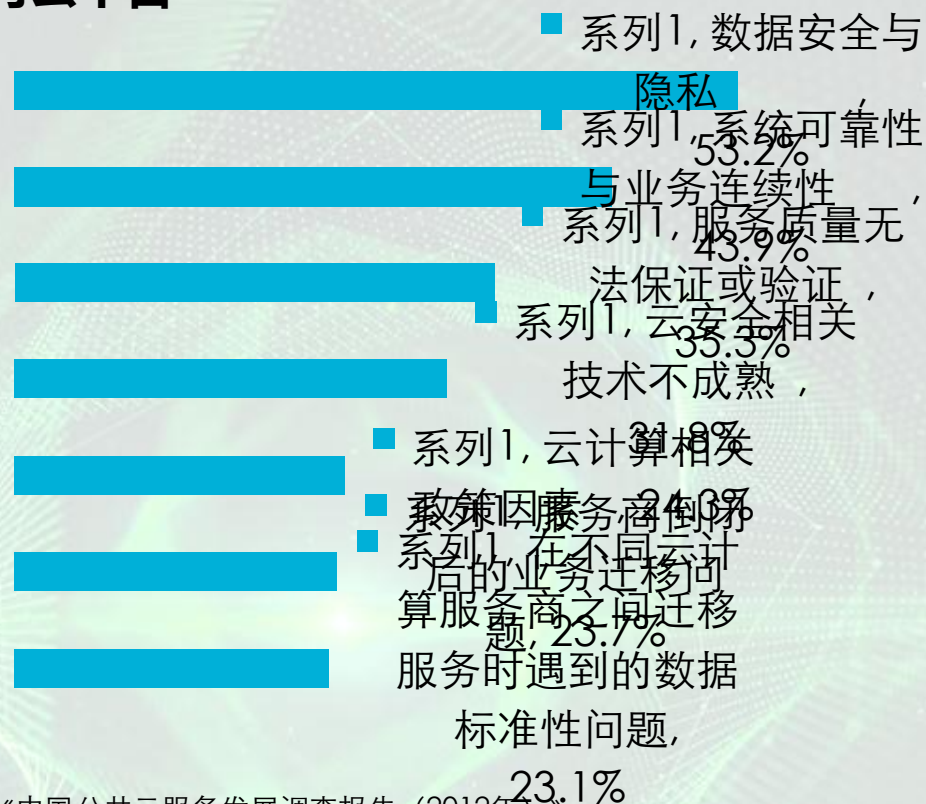


360互联网安全中心

上帝之手
运动员—服务商
裁判员—第三方



公有云平台



数据来源：工业和信息化部电信研究院《中国公共云服务发展调查报告（2012年）》

云服务商

可信、安全

第三方

监管、审计



中国互联网安全大会



360互联网安全中心

云平台的可信和安全

可信云认证

数据安全、服务质量、权益保障
完备、规范、真实、公开

Trusted Cloud Service ITU-T Y.3501

A set of requirements (performance, resiliency, reversibility) and transparency for governance, management and security to CSC

Trust Service AICPA SOC 2

美国注册会计师协会 服务组织风险控制报告

Controls of Security, Availability, Processing Integrity, Confidentiality and Privacy

可信的要求

数据安全	数据存储的持久性	服务质量	服务功能
	数据可销毁性		服务可用性
	数据可迁移性		服务资源调配能力
	数据私密性		故障恢复能力
	数据知情权		网络接入性能
	服务可审查性		服务计量准确性
权益保障	服务变更、终止条款	专项要求	运维管理要求
	服务赔偿条款		云服务性能要求
	用户约束条款		信息安全要求
	服务商免责条款		

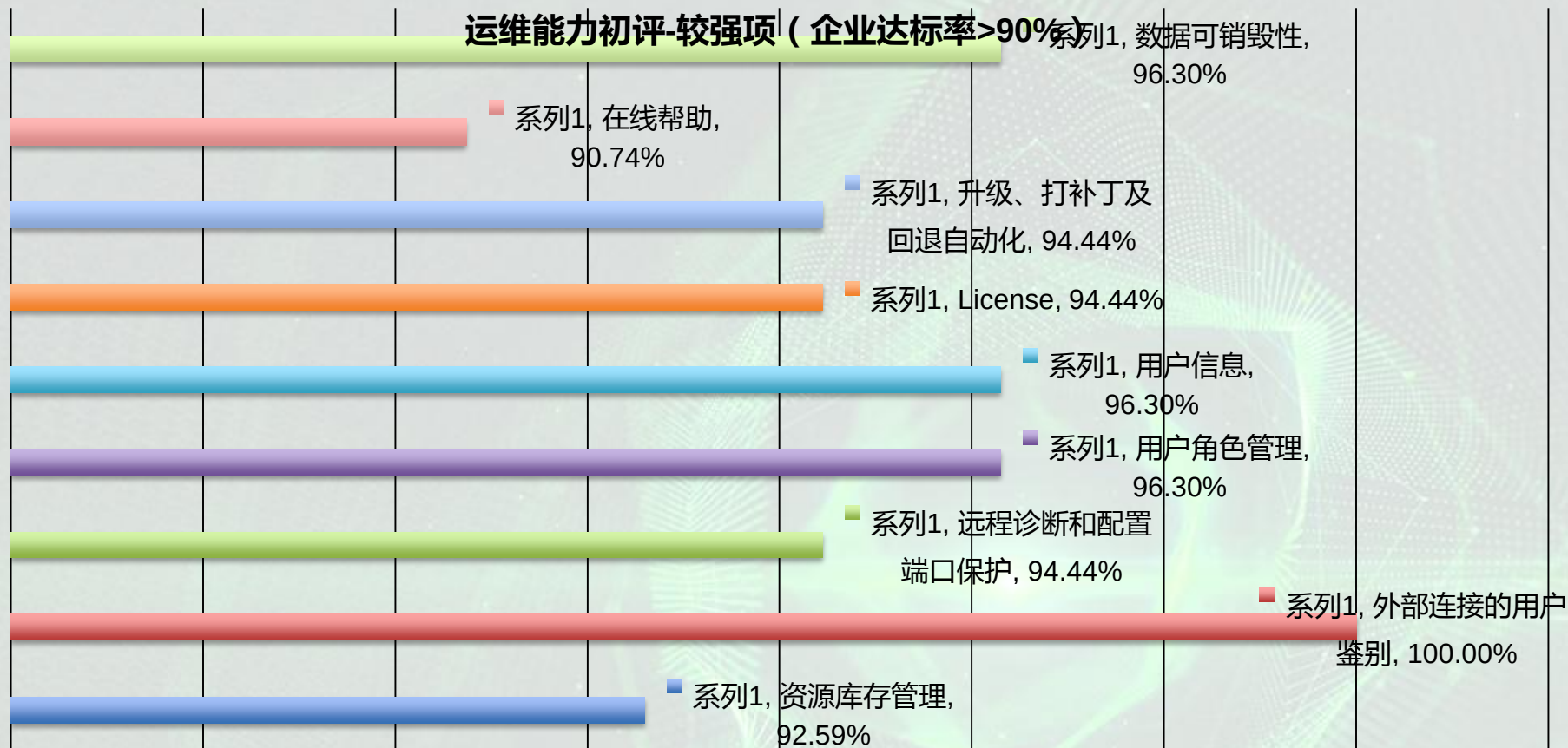
可信的要求-数据安全

数据存储的持久性	硬盘类型、硬盘损坏率、备份延迟时间、副本数等因素。
数据可销毁性	用户要求删除数据或设备在弃置、转售前必须将其所有数据彻底删除，并无法复原。
数据可迁移性	用户能够控制数据或主机镜像的迁移，保证启用或弃用该云服务时，数据能迁入和迁出。
数据私密性	承诺用户应有加密或隔离等手段保证同一资源池用户数据互不可见：ping，端口，报文
数据知情权	数据存储在哪些数据中心； 有几份拷贝，是否有冷备份； 数据位置用户是否可选； 当地与数据中心相关的法律法规； 用户数据的使用人和使用的数据类型，数据类型包括日志、用户个人信息等等； 有无跨境流动； 有无数据分析。
服务可审查性	用户在必要的条件下由于合规或是安全取证调查等原因可以提供相关的信息：如关键组件的运行日志、运维人员的操作记录。遵守国家相应的法律法规，配合政府监管部门的监管审查

- 验证是否具有双因子认证功能
- 验证是否具有云主机密钥登录功能
- 验证是否具有云主机远程访问控制功能
- 验证是否具有云主机用户访问控制功能
- 检测密码重置风险
- 检测弱口令爆破风险
- 检测异常错误风险
- 检测敏感信息泄露风险
- 检测SQL 注入风险
- 检测命令执行风险
- 检测代码注入风险
- 检测XSS 跨站攻击风险；
- 检测文件上传漏洞风险
- 检测安全配置风险
- 检测目录非授权浏览风险
- 检测HTTP 伪造请求风险
- 检测Webshell、暗链等风险
- 检测其他漏洞风险

可信的要求-运维管理

运维能力初评-较强项 (企业达标率>90%)

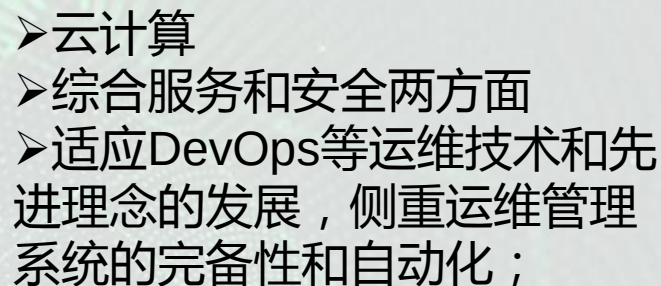


数据来源：根据可信云金牌运维评测报告，2016.03

运维能力初评--较弱项 (企业达标率<60%)



数据来源: 根据可信云金牌运维评测报告, 2016.03



信息安全管理体系
信息技术服务管理体系




可信的要求-运维管理-流程规范

服务台	●运维人员岗位职责说明 ●服务台与客户的联络方式 ●服务台职责 ●服务台管理制度	配置管理	●配置项管理 ●工作程序管理 ●关键成功因素
事件管理	●事件的记录和分类 ●事件处理 ●事件关闭 ●录入日志管理	发布管理	●版本测试 ●版本控制 ●版本部署及发布
问题管理	●问题确定和记录 ●问题分析和转交 ●监控问题 ●问题处理 ●问题录入日志管理	知识库管理	●是否有本公司的知识库
变更管理	●变更分类和记录 ●变更控制 ●变更分析 ●改进措施	报表管理	●报表分类统计 ●事件管理报表 ●问题管理报表 ●配置管理报表

可信的要求-运维管理-系统完备性

监控管理	●物理设备层 ●系统层 ●网络层 ●应用服务层 ●云平台层 ●存储层 ●业务层	统计报表管理	●资源统计报表 ●TopN报表 ●故障分析报表 ●事件统计报表
权限管理	●账号管理 ●角色管理 ●分域管理 ●密码管理	资产管理	●资产信息收集 ●资产变更管理 ●资产统计报表
告警管理	●系统故障预防设计 ●报警系统容灾 ●报警内容管理 ●故障检测和处理	工单管理	●工单申请 ●工单处理 ●工单取消/关闭
拓扑管理	●拓扑展示 ●自定义拓扑 ●网络拓扑	计费管理	●计费规则 ●计费配置
日志管理	●用户访问日志 ●运维人员操作日志 ●系统运行日志	安全管理	●堡垒机 ●防火墙 ●云网络流量监测 ●入侵检测 ●防DDOS攻击 ●主机安全防御 ●漏洞扫描系统 ●防病毒管理 ●敏感数据加密 ●数据冗余备份
软件管理	●软件预安装和预置 ●软件自动化批量安装 ●升级、打补丁及回退自动化		

可信的要求-运维管理-系统自动化性

网络管理自动化	●安全与权限管理自动化 ●监控与告警自动化 ●网络数据管理自动化 ●网络容量管理自动化 ●网络容灾自动管理
机器全生命周期管理自动化	●物理机器日常操作自动化 ●安全与权限管理自动化 ●监控与告警自动化 ●机器数据管理自动化
操作系统环境管理自动化	●操作系统日常操作自动化 ●安全与权限管理自动化 ●监控与告警自动化 ●操作系统数据管理自动化

可信的要求-运维审查情况

	电信运营商 IDC运营商背景	互联网商背景	设备商背景
流程制度	强	弱	中等
运维系统	弱 外包 自动化管理弱	强 自研 自动化管理强	中等



中国互联网安全大会



360互联网安全中心

云平台的监管和审计

为促进我国云计算创新发展,积极培育信息产业新业态,支持第三方机构开展云计算服务质量、可信度和网络安全等评估测评工作。引导云计算服务企业加强内部管理,提升服务质量和诚信水平,逐步建立云计算信任体系。

国务院印发《关于促进云计算创新发展培育信息产业新业态的意见》2015.1.30

事前

准入
认证

事中

监测
审计

事后

保险
赔偿

可信、安全指标

牌照准入

中国

- IAAS/PAAS IDC (互联网资源协作业务)
- SAAS 在线数据处理与交易处理业务类牌照、存储转发类业务牌照、信息服务业务牌照 (ICP牌照等)、呼叫中心类牌照、计算机类无需牌照

第三方认证

- 国际 : ISO27001、CSA
- 中国 : 可信云服务认证、党政机关使用云计算网络安全审查、等级保护认证等
- 美国 : FedRAMP
- 英国 : G-Cloud
- 日本 : 云计算信息披露制度
- 韩国 : 可信云服务商认证
- 德国 : 可信云计算基础设施认证

第三方监测



可信云云主机分级

第三方审计

AICPA SOC 2 VS ISO27001 CSA
审计 VS 认证

规范赔偿

承诺用户业务某项指标没有达到服务协议中承诺的要求，则会提供的具体赔偿方式
最低和最高赔偿额

云保险

国外：CloudInsure、Liberty Mutual提供

国内：可信云保险：中国电信、中国联通、万国数据、UCloud

- 服务商：数据丢失、服务不可用、DDOS、数据泄露
- 服务商客户：即将上线



中国互联网安全大会



360互联网安全中心

谢谢

liwei@ritt.cn